TCP 三次握手与 SYN Flood 攻击的关系探究



学　　号 2453359

姓　　名 李欣洋

专　　业 信息安全

课程名称 网络空间安全导论

日　　期 2025.10.25

摘要: 本研究报告探讨 TCP 三次握手机制与 SYN Flood 攻击的内在关系。研究内容包括 TCP 三次握手流程、半连接队列机制、SYN Flood 攻击原理及防御技术。研究方法采用文献分析、协议解析、原理推导和对比分析等方法。研究结论表明,SYN Flood 攻击根源于 TCP 三次握手设计中的缺陷,即服务器在收到 SYN 请求后必须立即分配资源并进入半连接状态,而攻击者可以通过伪造源 IP 发送大量 SYN 包,这样的做法几乎零成本,这种资源消耗的严重不对称性使攻击者能以极小代价耗尽服务器的半连接队列,导致正常用户无法建立连接。有效防御需采用 SYN Cookie、防火墙过滤、流量清洗等多层次综合方案。

关键词: TCP 三次握手,SYN Flood 攻击,半连接队列

目录:

1. 引言

    1.1 研究背景

    - DDoS 攻击的普遍性

    1.2 研究目的

    - 理解 SYN Flood 攻击原理

    1.3 研究意义

    - 揭示了 TCP 协议中的安全缺陷

    - 加深了计算机网络方面的理解

2. 原理分析

    2.1 TCP 三次握手机制分析

    - 第一次握手

    - 第二次握手

    - 第三次握手

    2.2 状态转换过程

    - 客户端状态机

    - 服务器状态机

    2.3 序列号与确认号机制

    2.4 半连接队列

    - 队列大小限制

    - 队列管理机制

    2.5 TCP 资源消耗分析

-系统资源限制

3. 分析与过程

3.1 SYN Flood 攻击原理

- 伪造源 IP 地址，发送大量 SYN 包

- 占用半连接队列

3.2 为什么 SYN Flood 攻击利用三次握手

4. 总结与展望

1. 引言

1. 1 研究背景

DDoS（Distributed Denial of Service，分布式拒绝服务）攻击是一种通过大量恶意流量或请求淹没目标（如网站、服务器、网络设备），使其无法正常为合法用户提供服务的网络攻击形式。该网络攻击方式在如今的网络环境中非常普遍。其类型可以分为，流量型，协议型，应用层。本研究报告所讨论的 SYN Flood 就是属于协议型

1. 2 研究目的

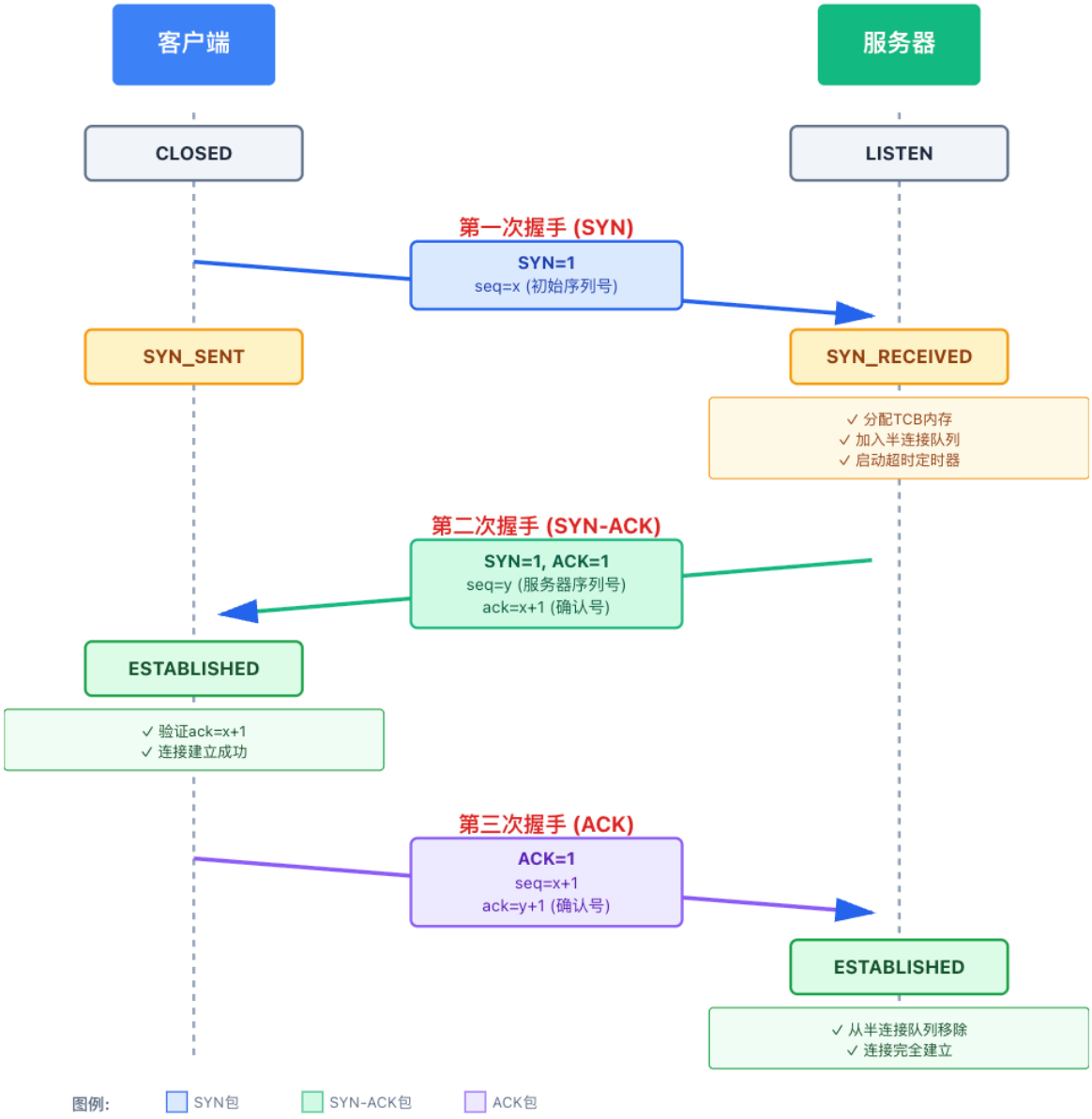
在理解 TCP 协议中的三次握手机制之后，来探究 SYN Flood 攻击的原理和三次握手之间的关系，探究为什么 SYN Flood 攻击选择利用 TCP 协议的三次握手机制来发起攻击。

1. 3 研究意义

揭示了 TCP 协议的安全缺陷，加深了计算机网络方面的理解

2. 原理分析

2. 1TCP 三次握手机制分析



在分析 TCP 三次握手机制之前，我们需要先知道，在 TCP 的头部中有一个“标志位”字段，其中可以设置多个控制位，在三次握手机制中，主要使用到 SYN（Synchronize 同步序号）位和 ACK（Acknowledgment 确认）位。其中 SYN 的作用是，用于建立连接，告诉对方“我准备好了，这个 seq 是我的初始序号“。而 ACK 的作用则是，用于确认对方的数据或请求，表示“我收到了你的信息”。所以，简单的理解三次握手的机制就是，客户端与服务器双方互相交换初始序列号并确认对方已收到，确保连接可靠建立。

2. 1_1 第一次握手

如上图所示，进行第一次握手时，发送方为客户端，接收方为服务器，此时发送的

报文内容为:SYN 标志位=1，表示这是一个连接的请求，seq=x，客户端随机生成的初始序列号，此时的客户端并不携带任何的数据知识想服务器发送一个请求来建立连接。

2. 1_2 第二次握手

在进行第二次握手时，服务器响应 SYN−ACK，此时的发送方变为服务器，接收方变为客户端，服务器发送的报文内容为 SYN 标志位=1，表示表示服务器也要同步序列号，ACK=1，表示这是对客户端 SYN 的确认，seq=y，服务器随机生成的初始序列号，ack=x+1，确认号, 表示期望收到客户端的下一个序列号。

注意，在这一步时，服务器会为这个 SYN 请求分配内存，用于记录客户端的 IP 等内容。

2. 1_3 第三次握手

客户端发送 ACK，此时的发送方又重新变回客户端，接收方变为服务器，此时的报文内容为，ACK 标志位=1，表示确认收到服务器的 SYN−ACK，seq=x+1，表示客户端的序列号递增，ack=y+1，确认号, 表示收到服务器序列号 y，可携带数据，从这一步开始可以携带应用层的数据（如 HTTP 请求）等。

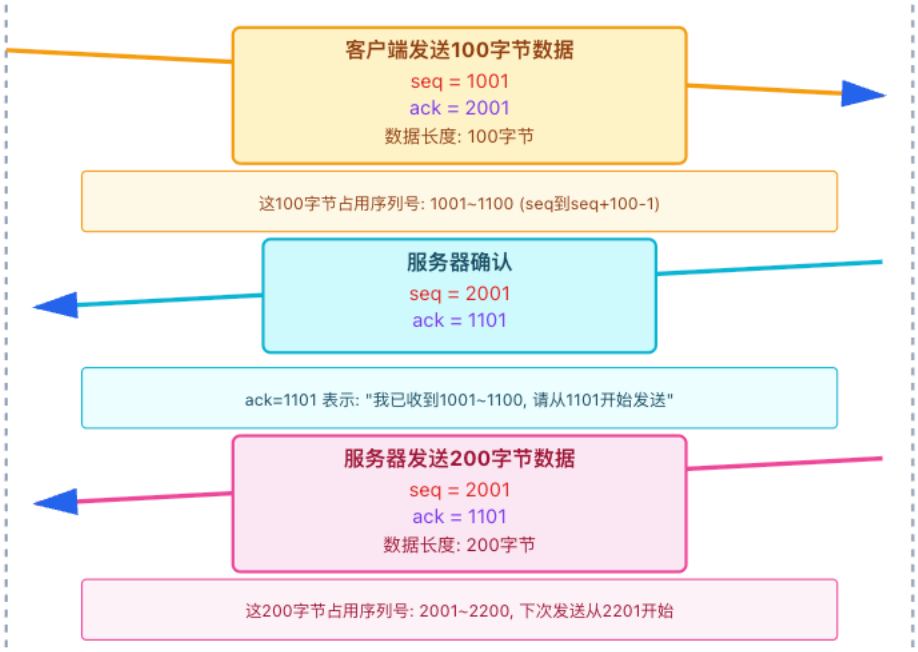
2. 2 状态转换过程

在整个三次握手的过程中，客户端和服务器都发生了状态的转变。客户端和服务器的初始状态分别是 CLOSED 和 LISTEN。在第一次握手结束之后，客户端的状态从 CLOSED 转变为了 SYN_SENT（同步已发送状态），而第二次握手结束之后，服务器由 LISTEN 转变为了 SYN_RECEIVED（同步已接收状态），在第三次握手结束之后，客户端和服务器均转变为 ESTABLISHED（已建立状态），可以开始进行数据的传输。

2. 3 序列号与确认号机制

在 2. 1 部分中提到了 seq（序列号）和 ack（确认号），接下来对他们的工作机制进行解释。序列号，是指是 TCP 报文段中每个字节数据的编号, 用于标识数据流中的位置，它的关键特性是，每发送一个字节, 序列号就加 1；确认号，表示接收方期望收到的下一个字节的序列号，而 ack = 已成功接收的最后一个字节的序列号 + 1。

例如在数据传输中的序列号和确认号机制：



2. 4 半连接队列

在 2. 1_2 中，有提到在 TCP 协议进行第二次握手时，服务器会为客户端发送的这个连接请求分配内存资源，用于记录客户端 IP，端口，序列号等信息。此时的连接还没有完全建立，而服务器会将这个半连接状态的请求加入到半连接队列之中，而在第三次握手成功完成之后，将这个连接请求移动到完全连接队列之中，随后释放其在半连接队列中所占用的资源。

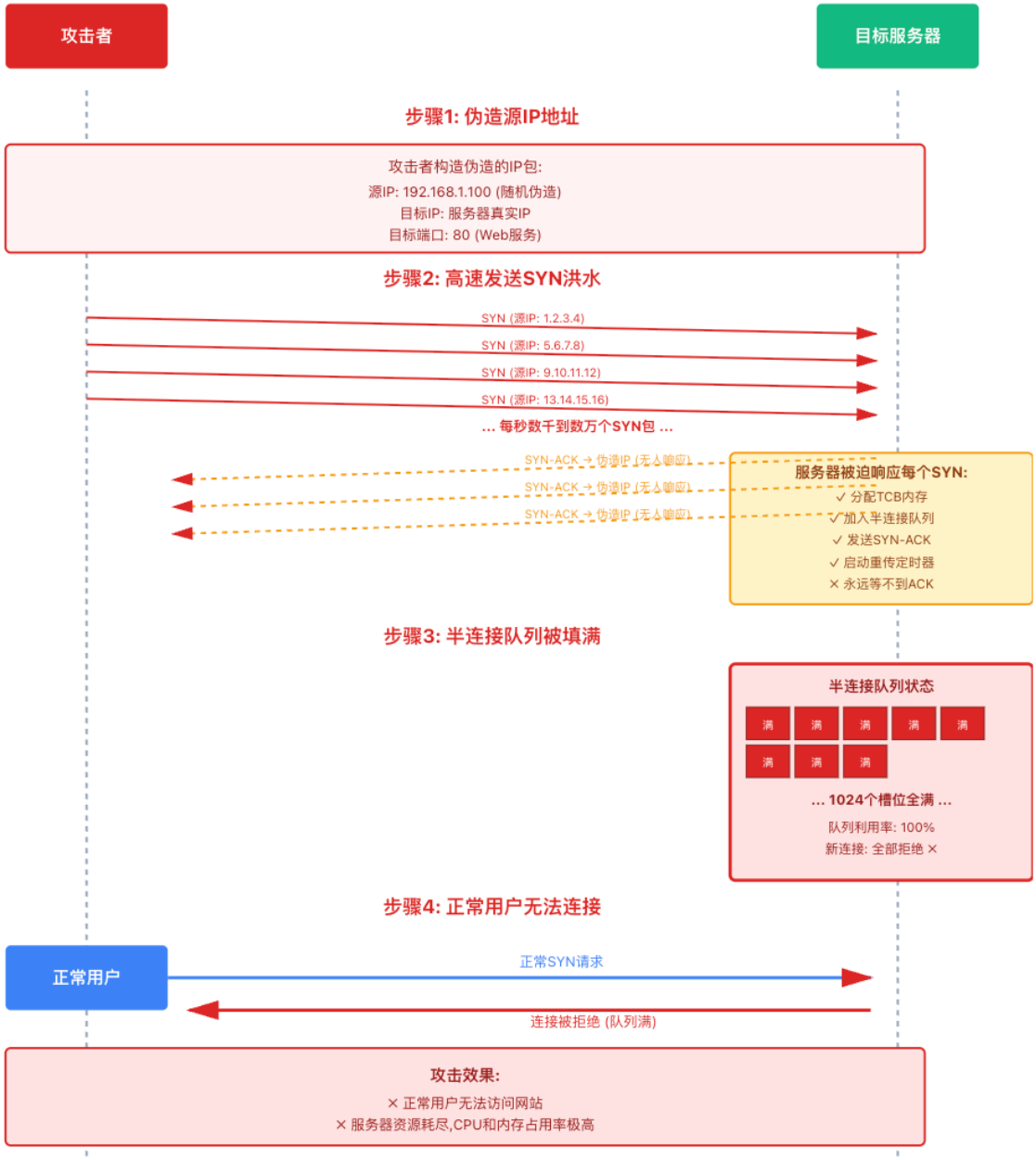
在半连接队列中，当内存资源被完全占满之后，服务器会拒绝对新的 SYN 请求。

2. 5TCP 资源消耗分析

注意到，在 2. 4 这一部分重要步骤中，服务器在第二次握手时，就为连接分配了内存资源，而这一部分的内存资源只有在第三次握手成功之后才会得到释放。我们知道，服务器的资源不可能是无穷多的，所以这个半连接队列的资源就一定是有上限的。此时有心的攻击者就可以故意伪造多个客户端 IP，来对服务器发起第一次握手，在服务器响应这个连接请求发出第二次握手之后，服务器就已经为本次的请求分配了内存资源，但是如果攻击者永远不发送第三次的握手，服务器就会进入长时间的等待，这一部分的内存资源就会迟迟得不到释放，当这样带有恶意攻击性的请求数量超过一定限度时，服务器就没有多余的内存资源分配给其他正常客户端的连接请求，会将正常用户的 SYN 请求拒绝，这就是接下来要谈到的 SYN Flood 攻击。

3. 分析与过程

3. 1SYN Flood 攻击原理



3. 1_1 伪造源 IP 地址，发送大量的 SYN 包

攻击者通过脚本或者自动化工具生成大量伪造的随机 IP，随后以极高的速率（可达到每秒发送数千到数万个）发送 SYN 包给服务器的 IP，这时服务器的 IP 被迫对这些 SYN 请求进行响应，同时会将这些请求加入 2. 4 部分提到的半连接队列之中。

如下是一个 Python 编写的自动生成大量 SYN 包发送至服务器 IP 的脚本片段。

```python
# 构造IP头部
def build_ip_header(src_ip, dst_ip):  1 个用法
    # 版本(4), 头长度(5), 服务类型(0), 总长度(40)
    version_ihl = (4 << 4) + 5
    total_length = 40  # IP头(20) + TCP头(20)

    ip_header = struct.pack( fmt: '!BBHHHBBH4s4s',
                            *v: version_ihl,  # 版本和头长度
                            0,  # 服务类型
                            total_length,  # 总长度
                            54321,  # 标识
                            0,  # 标志和片偏移
                            64,  # TTL
                            6,  # 协议(TCP)
                            0,  # 校验和(先填0)
                            socket.inet_aton(src_ip),  # 源IP - 这里可以伪造!
                            socket.inet_aton(dst_ip)  # 目标IP
                            )
    return ip_header
```

```python
# 构造TCP头部
def build_tcp_header(src_port, dst_port, seq):  1 个用法
    tcp_header = struct.pack( fmt: '!HHLLBBHHH',
                             *v: src_port,  # 源端口
                             dst_port,  # 目标端口
                             seq,  # 序列号
                             0,  # 确认号
                             (5 << 4),  # 数据偏移
                             0x02,  # 标志位: SYN=1
                             8192,  # 窗口大小
                             0,  # 校验和
                             0  # 紧急指针
                             )
    return tcp_header
```

3. 1_2 占用半连接队列

在这些请求都进入半连接队列之中之后，服务器同时会对这些请求分别分配内存。但是这些请求是永远也等不到来自客户端的第三次握手的，此时因为大量的恶意连接请求占用了服务器的半连接队列，导致正常用户的 SYN 请求被拒绝。从而达到攻击的目的。

其次，服务器有自动释放超时连接的能力，但是 3. 1_1 中也提到，攻击者发送 SYN 请求的速率是极高的，这个速率是大于服务器自动释放的速率的。

3. 2 为什么 SYN Flood 利用三次握手

因为三次握手机制的特性决定了，服务器需要去暂时保留那些尚未被完成的连接请求，即将它们存储到半连接队列中。这就决定了，服务器的半连接队列是可以被占用的。其次，服务器的资源终归是有限的，队列资源的有限性决定了队列有被恶意占满的风险。最后，服务器释放那些超时的请求的速率小与攻击者发送的速率。综上，攻击者选择利用三次握手的机制，就完成了对服务器的攻击！

4. 总结与展望

本次的研究让我学习到了很多的知识，首先学会了 SYN Flood 攻击和 TCP 三次握手之间的关系。其次，TCP 协议的学习内容隶属于计算机网络的学习部分，在写这个研究报告前，学习了一些计算机网络方面的内容，为计算机网络的学习打下了一些基础。

在研究的过程中也遇到了一些困难，这个课题的背景知识有很多是计算机网络方面的内容，而此前没有接触过过多计算机网络的知识，所以研究的起步稍显吃力。

在接触到网络空间安全导论这门课以后，可以自学部分计算机网络方面的知识，对后续的课程学习会有不错的提升！

参考文献：

1.《计算机网络 第六版》清华大学出版社 安德鲁·S·特南鲍姆 著 潘爱民 译